

VirtuEx 시스템 감사 보고서 (8차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 8차 감사 (종합 정기 감사 + UX 벤치마킹) 작성일: 2026-03-04 작성: 시스템 감사팀

1. 개요

8차 감사는 VirtuEx 프로젝트 전체를 대상으로 한 **종합 정기 감사**입니다. 7차 감사(2026-03-03) 이후 수정된 62건 전량의 수정 여부를 검증하고, 백엔드 8개 마이크로서비스, 프론트엔드 Next.js 15 애플리케이션, 인프라/Docker 구성, 보안, 데이터 무결성, UX/접근성, 성능 등 전 영역을 코드 레벨에서 재검사했습니다.

추가로 **토스증권, 업비트, 바이낸스, Robinhood** 등 주요 거래 플랫폼과의 기능/UX 비교 분석(벤치마킹)을 포함하여, 모의 거래 플랫폼으로서의 완성도를 평가합니다.

1.1 감사 범위

영역	검사 항목	신규 이슈
7차 수정 검증	7차 62건 수정 현황	—
보안 — 인증/인가	JWT, 역할 검증, 프록시 가드, CSP, 스토리지	7건
보안 — 입력 검증	DTO, CSP 리소스, 하드코딩	3건
데이터 무결성	Holdings 예약, 서킷 브레이커	3건
인프라/배포	7차 스킵 항목 검증	5건
프론트엔드 — 코드 품질/버그	PII 노출, 모놀리틱 파일, 중복 컴포넌트	5건
프론트엔드 — 접근성/UX	포커스 트랩, 색상 대비, 옵티미스틱 UI	5건
프론트엔드 — 성능/SEO	CSS transition, 번들 최적화, 폰트 로딩	4건
UX 벤치마킹	토스증권/업비트/바이낸스/Robinhood 비교	10건
합계		42건

2. 7차 감사 수정 현황

7차 감사에서 발견된 62건의 수정 여부를 전수 검증한 결과입니다.

2.1 수정 완료 (57건)

7차 #	항목	수정 내용
#1	주민번호 솔트 하드코딩	auth.service.ts 고정 솔트 전달 → VO 내부 랜덤 솔트 사용
#2	verify-sms 레이트 리밋 미흡	5req/60초로 강화
#3	check-duplicate 레이트 리밋 부재	엔드포인트별 레이트 리밋 추가

#4	비밀번호 재설정 복잡도 검증	@Matches 패턴 검증 추가
#5	TOTP 암호화에 JWT_SECRET 재사용	별도 TOTP_ENCRYPTION_KEY 환경변수 분리
#6	Email 컨트롤러 타이밍 공격	timingSafeEqual 적용
#7	INTERNAL_SERVICE_SECRET 빈 문자열	getOrThrow() 적용
#8	내부 서비스 CORS 외부 허용	CORS 비활성화, 내부 전용 주석 추가
#9	Admin Gateway 역할 검증 미적용	AdminRolesGuard 생성 및 AdminProxyController에 적용
#10	채팅 통계 프록시 x-internal-token 누락	내부 토큰 헤더 추가
#11	마이페이지 Admin API 직접 호출	사용자 전용 /api/user/notification-settings 엔드포인트 신설
#12	리더보드 userId 노출	마스킹 처리
#13	Swagger 프로덕션 노출	환경 분기 적용
#14	주문 수정 DTO MaxLength 누락	@MaxLength(50) 추가
#15	tradingStats days 상한 없음	Math.min(daysNum, 365) 적용
#16	회원가입 주소/우편번호 검증 미흡	필드별 @MaxLength, @Matches 추가
#17	채팅 방 이름 변경 DTO 없음	RenameRoomDto 생성
#18	x-user-id UUID 형식 미검증	UUID 패턴 검증 추가
#19	deposit/withdraw FOR UPDATE 락 누락	\$transaction + FOR UPDATE 적용
#20	settleBuy/Sell Holding FOR UPDATE 누락	Holding 읽기에 row lock 적용
#21	SELL 주문 취소 Holdings 복원 미구현	취소 시 release-holdings 호출 추가
#22	주문 수정 자금 미조정	modifyOrder 자금 재예약/해제 로직 추가
#23	checkTriggers 이중 발동	원자적 UPDATE ... WHERE triggered = false 적용
#24	Outbox 발행자 미구현	OutboxRelayService 스케줄러 구현
#25	정산 실패 DLQ 부재	DLQ/재처리 테이블 추가
#26	이벤트 버전 계산 로직 오류	버전 계산 단순화
#27	KRW 심볼 정규식 불일치	SYMBOL_REGEX 한국 주식 심볼 지원
#28	Account 잔고 DB CHECK 제약 없음	check-constraints.sql 추가
#29	Transaction referenceId unique 미적용	unique 제약 추가
#31	Redis Commander 인증 없이 접근	HTTP_USER, HTTP_PASSWORD 추가

#32	proxy.service URL localhost 기본값	URL 환경변수 참조 개선
#33	x-request-id 다운스트림 미전파	forward()에 전파 로직 추가
#34	AllExceptionsFilter 마이크로서비스 미적용	7개 서비스 main.ts에 필터 추가
#39	useRecentTrades side 버그	삼항연산자 수정
#40	Swagger URL localhost 하드코딩	NEXT_PUBLIC_API_URL 활용
#41	useCandlesticks 중복 aggregateCandles	조건 분기 로직 정리
#42	leaderboard 시뮬레이션 데이터	실제 데이터 기반으로 변경
#43	Header 로그아웃 ConfirmModal 미활용	공통 모달 적용
#44	accessToken 미퍼시스트 race condition	토큰 갱신 큐 적용
#45	not-found/error에 Next.js Link 미사용	<Link> 적용
#46	max-w-full 중복 클래스	중복 제거
#47	Next.js middleware 부재	middleware.ts 생성 (admin 보안 헤더)
#48	관리자 페이지 클라이언트 사이드만 보호	AdminGuard + admin layout.tsx 생성
#49	모달 aria-labelledby 미적용	접근성 속성 추가
#50	Dashboard 탭 ARIA role 누락	role="tab", aria-selected 추가
#51	admin/users 테이블 키보드 접근 불가	tabIndex, onKeyDown, role="link" 추가
#52	OrderSheet 닫기 aria-label	aria-label 추가
#53	lang="ko" 하드코딩	lang="en" + pre-hydrate 동적 설정
#54	BottomNav 터치 타겟	터치 영역 확대
#55	REST polling + WebSocket 동시 실행	WebSocket 연결 시 polling 비활성화
#56	useCandlesticks fetchLimit 50,000개	서버사이드 집계 + 제한 적용
#57	무거운 컴포넌트 dynamic import 미적용	CandlestickChart, NotificationBell dynamic import
#58	CSP unsafe-eval	프로덕션에서 unsafe-eval 제거
#59	주요 페이지 metadata 미설정	다수 페이지 layout.tsx + metadata 추가
#60	portfolio 1초마다 setNow	60초 interval로 변경
#61	admin/health localhost 하드코딩	환경변수 기반 동적 표시
#62	next/image unoptimized 플래그	최적화 플래그 조정

2.2 스킵 — 인프라/CI 전용 (5건, 8차 잔존 항목으로 재기록)

7차 #	항목	사유
#30	PostgreSQL/Redis 마이너 버전 미고정	배포 설정, 코드 변경 아님 → 8차 #15
#35	CI 테스트 커버리지 임계값 미설정	CI 파이프라인 개선 → 8차 #16
#36	컨테이너 이미지 취약점 스캔 없음	CI 파이프라인 개선 → 8차 #17
#37	Prometheus scrape 타겟 하드코딩	프로덕션 인프라 설정 → 8차 #18
#38	start-all.sh readiness probe	개발 스크립트 개선 → 8차 #19

3. 보안 감사 — 인증/인가 (7건)

#	위험도	항목	위치
1	상	SettingsProxyController AdminRolesGuard 미적용	settings-proxy.controller.ts:7
2	상	StatisticsProxyController AdminRolesGuard 미적용	statistics-proxy.controller.ts:26
3	상	AI 서비스 엔드포인트 인증 없음	analysis.controller.ts:11
4	상	Auth pre-hydration localStorage/sessionStorage 불일치	stores/auth.ts:41 vs layout.tsx:52
5	중	CSP font-src/style-src에 CDN 미포함	next.config.ts:38
6	중	관리자 설정 localStorage 저장 (XSS 노출)	stores/adminSettings.ts:129
7	하	토큰 sessionStorage 저장 (HttpOnly cookie 미사용)	stores/auth.ts:41

상세 설명:

- **#1:** SettingsProxyController 가 /api/admin/settings 경로에서 JwtAuthGuard 만 적용. AdminRolesGuard 미적용으로 인증된 일반 사용자가 시스템 설정(초기 자금, 수수료, 거래 시간, 세션 정책 등)을 읽기/수정 가능. AdminProxyController 에는 7차 수정으로 AdminRolesGuard 가 적용되었으나, 별도 파일인 Settings 프록시에는 누락
- **#2:** StatisticsProxyController 가 /api/statistics/* 경로에서 JwtAuthGuard 만 적용. AdminRolesGuard 미적용으로 인증된 일반 사용자가 가입 통계, 로그인 통계, 사용자 통계, 페이지뷰 통계 등 관리자 전용 통계 데이터에 무단 접근 가능. page-view POST는 공개 엔드포인트이므로 예외 처리 필요
- **#3:** AI 서비스의 AnalysisController 에 InternalAuthGuard / JwtAuthGuard 미적용. 네트워크 접근 가능 시 /analysis/signals , /analysis/portfolio 엔드포인트 무인증 호출 가능. 타 내부 서비스 (order-engine, portfolio, notification 등)는 모두 InternalAuthGuard 적용

- **#4:** 인증 스토어(`auth.ts:41`)가 `sessionStorage` 에 저장하나, 루트 레이아웃의 `pre-hydration` 스크립트 (`layout.tsx:52`)가 `localStorage.getItem('virtuex-auth')` 로 읽음. 스토리지 종류 불일치로 **pre-hydration**이 항상 실패하여:
 1. `data-authed` 속성 미설정 → CSS `auth-show / auth-hide` 클래스 미동작
 2. `AdminGuard` 의 `document.documentElement.dataset.authed` 체크 실패 → hydration 전 불필요한 리다이렉트 가능
 3. `data-role` , `data-username` 속성 미설정 → CSS `admin-show` 클래스 미동작
- **#5:** `next.config.ts` CSP에서 `font-src 'self' data:` 로 설정. `globals.css` 에서 `@import url('https://cdn.jsdelivr.net/...')` 로 Pretendard 폰트를 로드하나 CSP에 `https://cdn.jsdelivr.net` 미포함. **프로덕션에서 CSP가 폰트 스타일시트 및 폰트 파일을 차단**, 시스템 폰트로 폴백됨. `style-src` 에도 CDN URL 추가 필요
- **#6:** `adminSettings.ts` 가 `localStorage` 키 `virtuex-admin-settings` 에 거래 한도, 수수료율, 시스템 상태, 운영시간, 리스크 설정 등을 저장. XSS 공격 시 이 데이터를 읽거나 변조 가능. 백엔드 API에서 실제 값을 적용하므로 직접적 위험은 낮으나, 관리자에게 잘못된 캐시 데이터 표시 가능
- **#7:** `sessionStorage` 는 `localStorage` 보다 안전(탭 범위 제한)하나, JavaScript에서 접근 가능. `HttpOnly` + `Secure` + `SameSite` 쿠키 사용 시 XSS로부터 토큰 완전 보호 가능. 아키텍처 수준 변경 필요

4. 보안 감사 — 입력 검증 (3건)

#	위험도	항목	위치
8	● 중	AI 서비스 <code>analyzePortfolio</code> DTO 미적용	<code>analysis.controller.ts:21-22</code>
9	● 하	<code>skip-to-content</code> 링크 영문 하드코딩	<code>layout.tsx:76</code>
10	● 하	<code>global-error.tsx</code> 연락처 환경변수 미사용	<code>global-error.tsx:137-139</code>

상세 설명:

- **#8:** `analyzePortfolio()` 의 `@Body()` 파라미터가 인라인 타입 `{ holdings: { symbol: string; value: number }[] }` 으로 선언. NestJS의 `ValidationPipe` 는 클래스 기반 DTO만 검증하므로 **인라인 타입에는 `class-validator` 데코레이터 미적용**. `holdings` 배열 크기, `symbol` 형식, `value` 범위 검증 없이 AI 서비스로 전달
- **#9:** `layout.tsx` 의 `skip-to-content` 링크 텍스트가 `"Skip to content"` 로 영문 고정. 서버 컴포넌트에서 `useTranslation` 혹 사용 불가하여 발생한 아키텍처 한계. 국제화 영향 미미하나 일관성 저하
- **#10:** `global-error.tsx` 에 개인 이메일(`sknskin@naver.com`)과 전화번호(`010-7455-4829`)가 하드코딩. 동일 목적의 `error.tsx` 는 올바르게 `process.env.NEXT_PUBLIC_CONTACT_EMAIL / PHONE` 환경 변수를 사용. 빌드된 JS 번들에 개인정보가 노출되므로 환경변수로 대체 필요

5. 데이터 무결성 감사 (3건)

#	위험도	항목	위치
11	● 상	SELL 주문 Holdings 예약(reserve) TODO 스텝	<code>internal.controller.ts:131</code>

12	● 중	release-holdings 동일 TODO 스텝	internal.controller.ts:166
13	● 중	proxy circuit breaker 5xx 응답 처리	proxy.service.ts forward()

상세 설명:

- **#11:** reserve-holdings 엔드포인트가 보유량 존재 및 수량 충분 여부만 검증하고, **실제 예약 (reservedQuantity 차감)을 수행하지 않음**. TODO: Implement full holding reservation with a reservedQuantity column 주석과 logger.warn() 로그만 존재. 동일 사용자가 동시에 같은 종목의 매도 주문 복수 건을 제출하면 총 보유량을 초과하는 매도 주문이 접수될 수 있음. Holdings 테이블에 reservedQuantity 컬럼 추가 및 원자적 예약 로직 구현 필요
- **#12:** release-holdings 엔드포인트도 동일하게 TODO 스텝. 매도 주문 취소 시 예약 해제가 실질적으로 수행되지 않음. #11 구현 시 함께 구현 필요
- **#13:** proxy.service.ts 의 forward() 메서드에서 try-catch 로 Axios 에러를 처리하나, **HTTP 5xx 응답이 Axios의 정상 응답으로 처리되는 경우** (validateStatus 설정에 따라) circuit breaker 카운트에 반영되지 않을 수 있음. 5xx 응답도 실패로 카운트하도록 검증 필요

6. 인프라/배포 감사 (5건)

7차 감사에서 스킵된 인프라/CI 항목의 잔존 상태를 재확인합니다.

#	위험도	항목	위치
14	● 중	PostgreSQL/Redis 이미지 마이너 버전 미고정	docker-compose.yml L7, L38
15	● 중	CI 테스트 커버리지 임계값 미설정	ci.yml, Jest 설정
16	● 중	컨테이너 이미지 취약점 스캔 없음	.github/workflows/ci.yml
17	● 하	Prometheus scrape 타겟 하드코딩	prometheus.yml
18	● 하	start-all.sh readiness probe 미적용	scripts/start-all.sh

상세 설명:

- **#14:** postgres:16-alpine , redis:7-alpine 은 마이너/패치 미지정. 자동 빌드 시 호환성 문제 가능. postgres:16.8-alpine , redis:7.4-alpine 등 고정 권장 (7차 #30 잔존)
- **#15:** CI에 test:cov 스텝 존재하나 coverageThreshold 미설정. 70%+ 임계값 설정 권장 (7차 #35 잔존)
- **#16:** Docker 이미지 OS 레벨 CVE 미감지. Trivy/Snyk container scan 추가 권장 (7차 #36 잔존)
- **#17:** Prometheus 타겟이 host.docker.internal 고정. Linux 서버 미동작 (7차 #37 잔존)
- **#18:** 포트 LISTEN 상태만 확인, /health/ready HTTP 응답으로 변경 권장 (7차 #38 잔존)

7. 프론트엔드 감사 — 코드 품질/버그 (5건)

#	위험도	항목	위치
19	● 상	global-error.tsx 개인정보(PII) 하드코딩	global-error.tsx:137-139
20	● 중	대형 모듈리틱 파일 (help 60K+, admin 70KB+)	help/page.tsx, admin/stats/page.tsx

21	● 중	중복 UI 컴포넌트 미추출	admin/users, orders, mypage
22	● 중	토큰 갱신 실패 시 하드 리다이렉트	lib/api.ts:85-87
23	● 하	인라인 Toggle 컴포넌트 공용 미추출	admin/settings/page.tsx:28-58

상세 설명:

- **#19:** global-error.tsx 에 개인 이메일(sknskin@naver.com)과 전화번호(010-7455-4829)가 직접 하드코딩. 빌드된 JavaScript 번들에 포함되어 **모든 사용자에게 개인정보 노출**. error.tsx 는 올바르게 process.env.NEXT_PUBLIC_CONTACT_EMAIL / PHONE 을 사용하고 있어 패턴 불일치. 즉시 환경변수로 대체 필요
- **#20:** help/page.tsx 가 60,000+ 토큰(SVG 일러스트레이션 수십 개 인라인), admin/stats/page.tsx 와 admin/health/page.tsx 가 각 70KB+. 단일 파일에 차트, 데이터 페칭, 탭 콘텐츠 전부 포함. 유지보수성 저하 및 코드 분할 비효율
- **#21:** StatusDropdown 이 admin/users/page.tsx 와 orders/page.tsx 에 독립 정의. InfoRow 가 admin/users/[id]/page.tsx 와 mypage/page.tsx 에 중복. RoleBadge 가 admin/users/page.tsx 와 mypage/page.tsx 에 중복. 공용 @/components/ui/ 컴포넌트로 추출 권장
- **#22:** lib/api.ts 의 401 인터셉터에서 리프레시 토큰 갱신 실패 시 window.location.href = '/login' 으로 전체 페이지 리로드. 작성 중인 폼 데이터, 주문 입력 등 **모든 React 상태가 파괴됨**. Next.js 라우터 기반 소프트 네비게이션 또는 모달 알림으로 변경 권장
- **#23:** admin/settings/page.tsx 에 Toggle 컴포넌트가 인라인 정의. 다른 관리자 페이지에서 토글이 필요할 경우 중복 발생 가능. @/components/ui/Toggle 로 추출 권장

8. 프론트엔드 감사 — 접근성/UX (5건)

#	위험도	항목	위치
24	● 중	모달 포커스 트랩 미구현	OrderSheet.tsx:60-117, admin/users/[id]
25	● 중	text-quaternary 색상 대비 WCAG AA 미달	globals.css:19
26	● 중	관심종목 토글 옵티미스틱 업데이트 미적용	dashboard, asset detail
27	● 중	오더북/체결내역 로딩 스켈레톤 부재	asset/[symbol]/page.tsx
28	● 하	주문 취소 Undo 메커니즘 없음	orders/page.tsx

상세 설명:

- **#24:** OrderSheet 모달이 role="dialog", aria-modal="true", Escape 키 처리를 올바르게 구현하나, **포커스 트랩(focus trap)이 미구현**. Tab 키로 모달 뒤의 배경 요소에 접근 가능하여 WCAG 2.1 대화상자 요구사항 위반. admin/users/[id] 승인/거절 모달도 동일 이슈. 기존 ConfirmModal / BottomSheet 에는 포커스 트랩이 구현되어 있어 패턴 불일치
- **#25:** 다크 모드 기본 테마에서 --color-text-quaternary: #4E5968 이 --color-bg-primary: #17171C 배경 위 대비율 약 **2.4:1**. WCAG AA 기준 일반 텍스트 4.5:1, 대형 텍스트 3:1 모두 미충족. 타임스탬프, 보조 레이블, 메타데이터 등 앱 전반에서 광범위하게 사용되는 색상

- **#26:** 관심종목 추가/제거 토글이 서버 응답 대기 후 UI 갱신. 토스증권, 바이낸스 등은 즉시 시각적 피드백(옵티미스틱 업데이트) 제공. React Query `onMutate` 로 즉시 반영 후 실패 시 롤백하는 패턴 권장
- **#27:** 자산 상세 페이지의 오더북/체결내역 탭이 초기 데이터 로딩 중 빈 화면 표시. 차트 영역은 `ChartSkeleton` 으로 로딩 상태를 잘 처리하나 탭 콘텐츠는 스켈레톤 미적용
- **#28:** 주문 취소 시 `ConfirmModal` 로 확인(적절함)하지만, 취소 완료 후 되돌리기(Undo) 기능 없음. 토스증권은 주문 취소 후 5초간 Undo 스낵바를 제공. 모의 거래 플랫폼 특성상 실수 복구 기능이 교육적 가치가 큼

9. 프론트엔드 감사 — 성능/SEO (4건)

#	위험도	항목	위치
29	중	전체 요소 CSS transition 적용	<code>globals.css:68-72</code>
30	중	<code>help/page.tsx</code> 인라인 SVG 번들 포함	<code>help/page.tsx</code>
31	중	CDN 폰트 FOIT(Flash of Invisible Text) 위험	<code>globals.css:9</code>
32	하	에러 바운더리 세분화 부재	<code>asset/[symbol]</code> , <code>admin/*</code> , <code>mypage</code> 등

상세 설명:

- **#29:** `globals.css` 에서 `*`, `*::before`, `*::after` 에 6개 속성의 transition 적용. 테마 전환 시 수백 개 DOM 요소가 동시 애니메이션 발생. `prefers-reduced-motion: reduce` 에서는 올바르게 비활성화되나, 일반 사용자에게 초기 렌더 및 리렌더 시 불필요한 컴포지팅 비용 발생. 테마 전환이 필요한 특정 요소(`body`, `header`, `nav` 등)에만 적용 권장
- **#30:** `help/page.tsx` 에 수십 개의 SVG 와이어프레임 일러스트레이션이 인라인 정의. 'use client' 컴포넌트이므로 전체 SVG 데이터가 JavaScript 번들에 포함. 사용자가 하나의 섹션만 볼 수 있으나 모든 SVG가 다운로드됨. Lazy loading 또는 별도 SVG 파일로 분리 필요
- **#31:** `@import url('https://cdn.jsdelivr.net/...')` 로 Pretendard 폰트를 CDN에서 로딩. CDN 지연/장애 시 FOIT 발생 가능. `font-display: swap` 적용 또는 자체 호스팅 권장. 또한 CSP 미포함(#5)으로 프로덕션에서 차단될 수 있음
- **#32:** 에러 바운더리가 `app/error.tsx`, `(main)/error.tsx`, `dashboard/error.tsx`, `orders/error.tsx`, `portfolio/error.tsx` 에 존재. 그러나 `asset/[symbol]`, `admin/*` 하위 페이지, `mypage`, `leaderboard`, `community`, `news`, `help` 에는 개별 에러 바운더리 없음. 에러 발생 시 `(main)/error.tsx` 로 폴백되어 세밀한 에러 복구 불가

10. UX 벤치마킹 — 토스증권/업비트/바이낸스/Robinhood 비교 (10건)

주요 거래 플랫폼과의 기능 비교를 통해 VirtuEx의 UX 완성도를 평가합니다.

10.1 기능 비교 매트릭스

기능	토스증권	업비트	바이낸스	Robinhood	VirtuEx
시장가/지정가 주문	✓	✓	✓	✓	✓
손절/익절 주문	✓	✓	✓	✓	✓

OCO 주문	—	—	✓	—	—
트레이딩 스톱	—	—	✓	✓	—
비율 수량 선택 (25/50/75/100%)	—	✓	✓	✓	—
원클릭(퀵) 주문	✓	—	—	✓	—
주문 확인 다이얼로그	✓	✓	✓	✓	—
포트폴리오 가치 히스토리	✓	✓	✓	✓	—
관심종목	✓	✓	✓	✓	✓
성과 비교 (벤치마크)	—	—	✓	✓	—
실시간 캔들스틱 차트	✓	✓	✓	✓	✓
오더북 시각화	기본	고급	고급	—	기본
AI 매매 시그널	—	—	✓	—	✓
가격 알림	✓	✓	✓	✓	✓
변동률 알림	✓	✓	✓	✓	—
브라우저 푸시 알림	—	✓	✓	—	—
채팅/커뮤니티	—	—	채팅	—	✓
리더보드	—	—	—	—	✓
다국어 지원	✓	✓	✓	✓	✓
다크/라이트 테마	✓	✓	✓	✓	✓
계좌 초기화(리셋)	—	—	—	—	—
교육용 콘텐츠	✓	—	✓	✓	도움말만

10.2 벤치마킹 기반 개선 권장 (10건)

#	우선도	항목	참고 플랫폼
33	● 중	포트폴리오 가치 히스토리 차트 미구현	토스, Robinhood
34	● 중	비율 기반 수량 선택기 (25/50/75/100%) 미구현	업비트, 바이낸스
35	● 중	자산 상세 페이지 고정 매수/매도 바 미구현	토스, 바이낸스
36	● 중	주문 확인 다이얼로그 미구현	전체 플랫폼 공통
37	● 중	계좌 초기화(리셋) 기능 미구현	TradingView, Webull
38	● 중	교육용 인라인 툴팁 미구현 (도움말 페이지만 존재)	Robinhood, 바이낸스
39	● 하	성취/마일스톤 시스템 미구현	Robinhood

40	● 하	OCO (One-Cancels-Other) 주문 미구현	바이낸스
41	● 하	트레일링 스톱 주문 미구현	바이낸스, Robinhood
42	● 하	브라우저 푸시 알림 미구현 (Web Push API)	업비트, 바이낸스

상세 설명:

- **#33:** 포트폴리오 페이지에 자산 배분 파이차트, P&L 분석, 리스크 지표 등 우수한 분석 도구가 있으나, **시간 경과에 따른 포트폴리오 총 가치 변화를 보여주는 시계열 차트가 없음**. Robinhood의 시그니처 기능이며 토스증권도 '내 투자 수익률' 그래프를 제공. 일간/주간/월간 누적 가치 그래프 추가 권장
- **#34:** 바이낸스와 업비트는 주문 수량 입력 시 **25% / 50% / 75% / 100% 버튼**을 제공하여 가용 잔고 대비 비율로 빠르게 수량 설정 가능. VirtuEx OrderForm에 비율 버튼 추가 시 주문 편의성 크게 향상
- **#35:** 자산 상세 페이지(/asset/[symbol])에서 차트를 스크롤할 때 매수/매도 버튼이 화면 밖으로 사라짐. 토스증권, 바이낸스 모두 **매수/매도 버튼을 화면 하단에 고정(sticky)**. 항시 주문 가능하도록 고정 바 구현 권장
- **#36:** 현재 주문 제출 시 확인 단계 없이 즉시 서버로 전송. **모든 주요 거래 플랫폼이 주문 요약과 최종 확인 다이얼로그를 제공**. 특히 모의 거래 플랫폼에서 교육적 목적으로 주문 확인 화면은 필수
- **#37:** 모의 거래 플랫폼(TradingView Paper, Webull Paper, thinkorswim)은 **계좌 초기화(리셋) 기능**을 제공하여 사용자가 초기 자금 상태로 되돌릴 수 있음. VirtuEx에서 학습 완료 후 새로 시작하고 싶은 사용자를 위한 리셋 기능 필요
- **#38:** Robinhood와 바이낸스는 금융 용어와 기능에 대한 **인라인 톨팁/해설**을 제공 (예: "지정가 주문이란?", "P&L이란?"). VirtuEx는 상세한 도움말 페이지(help)가 있으나, 주문 폼이나 포트폴리오 화면에서 직접 확인할 수 있는 컨텍스트 도움말이 없음. 처음 사용하는 학습자에게 인라인 교육이 더 효과적
- **#39:** Robinhood 스타일의 마일스톤 배지 시스템 (첫 거래 완료, 첫 수익 달성, 10종목 분산 투자 등). 기존 리더보드와 시너지 가능. 과도한 게이미피케이션은 지양하되 교육적 동기부여로 활용
- **#40:** 바이낸스의 OCO(One-Cancels-Other) 주문은 손절과 익절을 동시 설정. 하나 발동 시 나머지 자동 취소. 리스크 관리 교육에 효과적
- **#41:** 바이낸스, Robinhood의 트레일링 스톱은 유리한 가격 방향으로 스톱 가격이 자동 추종. 추세 추종 전략 학습에 활용
- **#42:** Web Push API를 통한 브라우저 푸시 알림. 탭 비활성 상태에서도 주문 체결, 가격 알림 등을 수신. 웹 기반 트레이딩 플랫폼의 주요 한계 극복

11. 종합 평가

11.1 위험도별 분류

위험도	건수	비율
● 상 (Critical)	6건	14.3%
● 중 (Medium)	24건	57.1%
● 하 (Low/Info)	12건	28.6%
합계	42건	100%

11.2 영역별 성숙도 (7차 대비)

항목	7차	8차	변화	비고
인증/인가	4.0/5	4.0/5	—	7차 수정 완료, Settings/Statistics 프록시 가드 누락 발견
입력 검증	4.0/5	4.5/5	▲+0.5	전반적 DTO 검증 강화, AI 서비스 DTO 미적용 잔존
데이터 무결성	3.0/5	3.5/5	▲+0.5	FOR UPDATE/Outbox/DLQ 구현, Holdings 예약 TODO 잔존
인프라/배포	4.0/5	4.0/5	—	AllExceptionsFilter 전파 완료, CI/버전 고정 미진전
프론트엔드 접근성/UX	3.0/5	3.5/5	▲+0.5	AdminGuard/middleware/ARIA 개선, 포커스 트랩/색상 대비 잔존
프론트엔드 코드 품질	3.5/5	4.0/5	▲+0.5	버그 수정 완료, PII 하드코딩/모놀리틱 파일 잔존
SEO/성능	2.5/5	3.5/5	▲+1.0	metadata/dynamic import 추가, CSP 폰트/SVG 번들 잔존
UX 완성도 (신규)	—	3.5/5	신규	핵심 기능 구현, 포트폴리오 히스토리/주문 확인 등 미구현
종합	3.4/5	3.8/5	▲+0.4	

11.3 누적 감사 현황

차수	유형	발견	수정	스킵	미수정
1차	신규 감사	36	36	0	0
2차	신규 감사	50	45	4	1
3차	수정 검증	0	—	—	—
4차	신규 감사	79	79	0	0
5차	수정 검증	0	—	—	—
6차	종합 심층 감사	75	47	0	28
7차	종합 정기 감사	62	57	5	0
8차	종합 감사 + UX 벤치마킹	42	미수정	0	42
누적		344	264	9	71

11.4 즉시 수정 권장 사항 (상 위험도 6건)

- SettingsProxyController AdminRolesGuard (#1)** — @UseGuards(JwtAuthGuard, AdminRolesGuard) 추가
- StatisticsProxyController AdminRolesGuard (#2)** — 관리자 통계 엔드포인트에 역할 가드 추가 (page-view POST는 예외)
- AI 서비스 인증 없음 (#3)** — AnalysisController 에 InternalAuthGuard 적용

4. **Auth sessionStorage/localStorage 불일치 (#4)** — pre-hydration 스크립트를 `sessionStorage` 로 변경 또는 auth store를 `localStorage` 로 변경
5. **SELL Holdings 예약 TODO 스텝 (#11)** — `reservedQuantity` 컬럼 추가 및 원자적 예약 구현
6. **global-error.tsx PII 하드코딩 (#19)** — 환경변수 `NEXT_PUBLIC_CONTACT_EMAIL / PHONE` 사용

11.5 7차 대비 주요 개선 사항

- **보안 대폭 강화:** TOTP 키 분리, AllExceptionsFilter 전체 서비스 적용, AdminGuard + middleware 신설, Redis Commander 인증 추가
- **데이터 무결성 핵심 수정:** deposit/withdraw FOR UPDATE 적용, Holdings row lock, 주문 수정 자금 조정, checkTriggers 원자적 업데이트, Outbox 발행자 구현, DLQ 추가
- **프론트엔드 접근성 향상:** admin 키보드 내비게이션, ARIA role/label 추가, ScrollToTop, 토스트 알림 보완, 관심종목 빈 상태 UI
- **SEO/성능 개선:** CandlestickChart/NotificationBell dynamic import, 다수 페이지 metadata 추가, CSP unsafe-eval 프로덕션 제거
- **7차 62건 중 57건 수정 완료 (91.9% 수정률)**

11.6 프로젝트 강점

- **마이크로서비스 아키텍처:** 8개 서비스 분리 + CQRS/이벤트 소싱 + Outbox 패턴 + DLQ
- **인증 체계:** JWT + 2FA(TOTP) + 계정 잠금 + timing-safe 비교 + 다단계 레이트 리밋 + AdminRolesGuard
- **인프라 구성:** Docker Compose + Prometheus + Grafana + Jaeger + 구조화된 헬스체크 + AllExceptionsFilter 전체 적용
- **프론트엔드 설계:** TypeScript strict, Zustand + React Query, WebSocket 실시간 가격, dynamic import, 다국어 i18n
- **거래 기능 완성도:** 시장가/지정가/손절/익절 주문, 실시간 오더북, 캔들스틱 차트, AI 매매 시그널, 가격 알림
- **UX 차별점:** 리더보드, 채팅/커뮤니티, 스포트라이트 검색, 가격 톱 플래시 애니메이션, 환율 변환
- **코드 품질:** ESLint/Prettier/Husky, `console.log` 없음, `as any / @ts-ignore` 없음, 접근성 기본 구현

11.7 결론

7차 감사 이후 **57건이 수정 완료**되어 91.9%의 높은 수정률을 달성했습니다. 특히 데이터 무결성 영역에서 FOR UPDATE 락, Outbox 발행자, DLQ 구현 등 핵심 금융 로직이 대폭 보강되었고, 프론트엔드에서는 AdminGuard, middleware, ARIA 접근성, dynamic import 등 구조적 개선이 이루어졌습니다.

8차 감사에서는 **42건의 신규 이슈**를 발견했으며, 핵심 우선순위는 다음과 같습니다:

1. **인증/인가 보안 갭** (6건 중 4건 🚨): SettingsProxy/StatisticsProxy의 AdminRolesGuard 누락, AI 서비스 무인증, sessionStorage/localStorage 불일치. 이 4건은 **즉시 수정 필요**
2. **데이터 무결성:** Holdings 예약 TODO 스텝은 동시 매도 시 초과매도 위험으로 조속한 구현 필요
3. **UX 벤치마킹:** 포트폴리오 가치 히스토리 차트, 비율 수량 선택기, 주문 확인 다이얼로그, 계좌 리셋은 모의 거래 플랫폼으로서 경쟁력을 좌우하는 핵심 기능

종합 성숙도 점수는 7차 3.4에서 **8차 3.8로 0.4점 상승**하여, 보안 및 데이터 무결성 영역에서 유의미한 개선을 확인했습니다. SEO/성능 영역은 1.0점 상승으로 가장 큰 개선폭을 보였습니다.

본 보고서는 VirtuEx 시스템의 8차 종합 정기 감사 + UX 벤치마킹 결과입니다. 2026-03-04 기준 소스 코드를 대상으로 하며, 토스증권/업비트/바이낸스/Robinhood 공개 자료를 참조했습니다.